Sonderthemen OT & KI

Vorlesungsskript · Sitzung 9 · Grundlagen der Resilienz

Prof. Dr. Dirk Loomans

29. September 2026

Vorbemerkung: Dieses Skript dient als Vorlesungsbegleitung und erhebt keinen akademischen Anspruch. Dennoch kann es bei der Klausurvorbereitung hilfreich sein. Kommentare und Verbesserungsvorschläge gerne an den Autor über dirk.loomans@hs-mainz.de.

Die mit „Hinweis zur Aktualität“ und „Ergänzung zur Vorlesung“ markierten Kästen sowie die Abbildungen wurden bei der Überführung ins Quarto-Projekt ergänzt. Der übrige Text entspricht dem Skript aus dem Wintersemester 2025/26; korrigiert wurden nur Tipp- und Umbruchfehler.

Kapitel 1 – Einordnung & Zielsetzung von OT-Resilienz

Operational Technology (OT) umfasst alle industriellen und betriebstechnischen Systeme, die physische Prozesse steuern, überwachen oder automatisieren. Dazu gehören Produktionsanlagen, Energieversorgungssysteme, Verkehrsleitsysteme, Wasseraufbereitung, Gebäudetechnik, Medizintechnik und viele weitere Infrastrukturen, deren Ausfall unmittelbar reale Auswirkungen auf Menschen, Umwelt oder Wirtschaft hätte. Anders als klassische Informationstechnologie (IT), die primär Daten verarbeitet, interagiert OT direkt mit der physischen Welt.

1.1 Was ist OT? Abgrenzung zur IT

Informationstechnologie (IT) ist darauf ausgelegt, Daten zu speichern, zu verarbeiten und auszutauschen. OT hingegen steuert **physische Prozesse**: Roboter bewegen Bauteile, Ventile öffnen oder schließen, Turbinen drehen sich, Bahnsignale schalten, Pumpen fördern Wasser.

Damit ergeben sich drei zentrale Unterschiede:

- **Zielsetzung**

  IT zielt auf Informationsverarbeitung, OT auf **Betriebssicherheit, Prozesskontinuität und physische Outputqualität**.

- **Prioritäten**

  IT folgt typischerweise der CIA-Triade (Confidentiality – Integrity – Availability). OT hat eine andere Reihenfolge: **Safety – Availability – Integrity – Confidentiality**.

- **Technische Eigenschaften**

  OT-Systeme sind oft schwer aktualisierbar, besitzen lange Lebenszyklen (10–30 Jahre), laufen auf spezialisierten Protokollen und sind häufig nur eingeschränkt netzwerkfähig.

OT und IT wachsen jedoch zunehmend zusammen — durch Digitalisierung, IIoT (Industrial Internet of Things), Cloud-Integration und Plattformdienste. Diese Konvergenz erzeugt neue Angriffspunkte und macht OT-Resilienz zu einem strategischen Thema.

1.2 Typische OT-Umgebungen

Zu OT-Systemen zählen u. a.:

- Industrieanlagen und Fertigungsstraßen
- Energie- und Wasserversorgung (KRITIS)
- Verkehrs- und Leitsysteme (z. B. Ampeln, Bahnsignale)
- Chemische und petrochemische Anlagen
- Medizintechnische Systeme
- Gebäudeautomation (z. B. Heizungssteuerungen, Aufzüge)
- Logistik- und Lagerautomatisierung

Gemeinsam ist ihnen: Sie müssen **kontinuierlich und sicher funktionieren**, oft 24/7, unabhängig von IT-Störungen.

1.3 Warum OT-Resilienz heute ein Top-Thema ist

Mehrere Entwicklungen führen dazu, dass OT heute deutlich gefährdeter ist als noch vor zehn Jahren:

A. Digitalisierung & Vernetzung OT-Systeme, die früher isoliert liefen, sind heute:

- über Remote Access wartbar
- mit IT-Netzen verbunden
- mit Cloud-Diensten integriert
- durch IIoT-Sensoren vernetzt

Dadurch steigt die Angriffsfläche erheblich.

B. Zunahme gezielter Angriffe Cyberangriffe auf Produktions- und Versorgungssysteme nehmen zu — teils durch Staaten, teils durch organisierte Kriminalität. Beispiele wie Stuxnet, Triton oder Colonial Pipeline zeigen, dass Angreifer physische Effekte in Kauf nehmen oder bewusst anstreben.

C. Safety & Security verschränken sich Ein Cybervorfall kann heute nicht nur Daten betreffen, sondern **Maschinenbewegungen, chemische Reaktionen oder kritische Versorgungsprozesse** beeinflussen. Dadurch entstehen Risiken für:

- Menschenleben
- Umwelt
- Betriebsfähigkeit
- gesellschaftliche Versorgung

D. Abhängigkeit von Lieferketten Moderne OT-Systeme sind nicht isoliert gebaut, sondern bestehen aus Komponenten vieler Hersteller — oft mit proprietären Firmware-Versionen, eingeschränkter Updatefähigkeit und langen Supportzyklen. Das macht Angriffe über Zulieferer realistischer.

E. Regulatorische Anforderungen Regelwerke wie KRITIS-Verordnung, NIS-2, IEC 62443 und ISO 27019 verlangen inzwischen explizit Maßnahmen zur Cyber- und Betriebsresilienz von OT-Systemen.

1.4 Unterschiedliche Resilienzanforderungen: Sicherheit, Verfügbarkeit, Safety

OT-Resilienz ist nicht einfach „IT-Resilienz in einer Fabrikhalle“. Sie folgt eigenen Prioritäten:

- **Safety:** Schutz von Menschen und Umwelt

- **Availability:** Produktions- oder Prozesskontinuität
- **Integrity:** korrekte Steuerbefehle & Sensordaten
- **Confidentiality:** weniger kritisch als in der IT, aber zunehmend relevant

Diese Reihenfolge ist entscheidend:

Ein Sicherheitsupdate, das eine Maschine sekundenlang stoppt, kann in einem Stahlwerk oder OP-Saal gefährlicher sein als eine bekannte Schwachstelle.

1.5 Zielsetzung des Kapitels in der Vorlesung

Das Kapitel soll den Studierenden ein grundlegendes Verständnis vermitteln:

- wie OT sich technisch und organisatorisch von IT unterscheidet
- warum OT-Resilienz ein eigenes Fachgebiet ist
- welche Risiken durch Cyberangriffe auf OT entstehen
- warum klassische IT-Security dort nicht ausreicht
- welche Rolle OT-Resilienz in modernen Sicherheitsprogrammen spielt
- wie Safety, Security und Resilience zusammenwirken müssen

Für Erstsemester im Studiengang **Cyber Security Management** ist dieses Kapitel eine Brücke zwischen abstrakten Resilienzprinzipien und ihrem realen Einsatz in kritischen Infrastrukturen und industriellen Umgebungen.

Kapitel 2 – OT im Kontext von Cyber-Resilienz

Operational Technology (OT) spielt eine zentrale Rolle in industriellen, kritischen und infrastrukturellen Prozessen. Deshalb unterscheidet sich ihre Resilienzbetrachtung grundlegend von derjenigen klassischer Informationstechnologie (IT). Während IT-Resilienz sich primär auf Datenverfügbarkeit, Integrität und Informationssicherheit bezieht, erweitert OT-Resilienz diese Perspektive um physische, sicherheitsrelevante und prozesskritische Aspekte.

Dieses Kapitel erklärt die Besonderheiten von OT-Systemen, die Unterschiede zu IT-Sicherheitsmodellen und die Rolle von OT in einem ganzheitlichen Resilienzansatz.

2.1 Besonderheiten von OT-Systemen

OT-Umgebungen haben eine Reihe von Merkmalen, die sie deutlich von klassischen IT-Umgebungen unterscheiden:

A. Lange Lebenszyklen OT-Systeme sind für Betriebszeiten von 10 bis 30 Jahren ausgelegt. Das bedeutet:

- veraltete Betriebssysteme
- fehlende Updatefähigkeit
- proprietäre Protokolle
- Abhängigkeit von Hersteller-Support

B. Safety-Relevanz Fehlfunktionen haben physische Konsequenzen:

- Roboter stoppen nicht rechtzeitig
- Ventile öffnen ungeplant

- Stromnetze destabilisieren sich
- Ampelanlagen oder medizinische Geräte fallen aus

C. Echtzeit-Anforderungen Viele OT-Systeme müssen deterministisch arbeiten. Beispiel: Steuerbefehle müssen in Millisekunden ankommen. Hohe Latenz, Paketverlust oder Jitter können Prozesse gefährden.

D. Schwache Authentisierung & veraltete Protokolle Viele OT-Geräte kennen:

- keine Verschlüsselung
- keine integrierte Authentifizierung
- keine Rollenmodelle
- keine zeitgemäßen Sicherheitsmechanismen

Das öffnet Angreifern Türen, die in der IT längst geschlossen wären.

E. Hohe Verfügbarkeitsanforderungen OT-Systeme dürfen oft **nicht abgeschaltet werden**, selbst für Updates nicht. Ein Firmware-Update kann einen Produktionsstopp im Millionenbereich verursachen.

Diese Bedingungen machen klassische Sicherheitsansätze weniger wirksam oder sogar gefährlich — und erklären, warum OT-Resilienz ein Spezialthema ist.

2.2 Unterschiedliche Bedrohungsmodelle gegenüber IT

Die Bedrohungslandschaft für OT unterscheidet sich grundlegend:

A. Angriffe zielen auf physische Effekte Während IT-Angreifer meist Daten stehlen oder verschlüsseln wollen, geht es in OT häufig um:

- Produktionsstillstände
- Anlagenmanipulation
- Überlastung kritischer Komponenten
- Zerstörung von Geräten
- Gefährdung von Menschenleben

B. Motivlage: andere Akteure, andere Ziele Typische Angreifer in OT:

- Staaten oder staatlich unterstützte Gruppen
- Cyberkriminelle mit Fokus auf Erpressung
- Aktivisten (z. B. Öl-, Chemie-, Energieproteste)
- Insider (z. B. Wartungstechniker, Auftragnehmer)
- Wettbewerber (Industriespionage)

OT wird zunehmend als strategisches Ziel gesehen, z. B. zur Destabilisierung von Lieferketten oder kritischen Infrastrukturen.

C. Eingeschränkte Sichtbarkeit Viele OT-Systeme erzeugen:

- keine Logs
- keine Telemetrie
- keine verwertbaren Monitoring-Signale

Dadurch bleibt ein Angriff oft **lange unentdeckt**.

D. Laterale Bewegung über IT-zu-OT-Pfade Typisches Einfallstor:

- Ein Angreifer kompromittiert IT-Systeme (z. B. durch Phishing)
- Er bewegt sich unbemerkt über schlecht isolierte Übergänge
- Er infiltriert die OT, die weniger geschützt ist

Diese IT/OT-Konvergenz ist ein Hauptgrund für heutige OT-Angriffe.

2.3 Der Dreiklang: Safety – Security – Resilience

Ein zentrales Unterscheidungsmerkmal von OT-Sicherheitsmodellen ist der Dreiklang aus:

A. Safety Schutz von Menschen und Umwelt vor Fehlfunktionen der Anlagen.

B. Security Schutz der OT-Systeme vor Cyberangriffen und Manipulation.

C. Resilience Fähigkeit, bei Störungen oder Angriffen weiterzuarbeiten bzw. sich schnell zu erholen.

Während in der IT Security oft im Mittelpunkt steht, ist OT ein Gleichgewichtssystem:

- Safety darf durch Security-Maßnahmen nicht gefährdet werden.
- Security darf die Verfügbarkeit nicht beeinträchtigen.
- Resilience gleicht unvermeidbare Störungen aus.

Beispiele:

- Ein Sicherheitspatch, der die Steuerung für 2 Minuten offline setzt → kritisch
- Ein Netzwerksegment, das falsch konfiguriert wird und Sensoren trennt → gefährlich
- Ein SOC, das böswillige Anomalien entdeckt → wichtig, aber nur wenn es OT-sensibel agiert

OT-Resilienz bedeutet also immer **Schutz ohne Beeinträchtigung des physischen Betriebs**.

2.4 Auswirkungen von Störungen: Von Produktionsausfall bis Menschenleben

Eine Störung in der OT hat direkte und indirekte Folgen:

Direkte Effekte

- Anlagenstillstände
- Qualitätsminderung
- Rohstoffverlust
- Beschädigung von Maschinen

Indirekte oder sekundäre Effekte

- Lieferkettenunterbrechungen
- finanzielle Verluste
- rechtliche Konsequenzen
- Umweltschäden
- Gefährdung von Menschenleben

Im Extremfall: Eine kompromittierte Steuerlogik kann Explosionen auslösen, chemische Reaktionen manipulieren oder kritische Energieanlagen destabilisieren.

2.5 Typische Incident-Szenarien

Hier einige der wichtigsten OT-Resilienz-Szenarien:

1. Ransomware in der Produktionssteuerung

Angriff auf ein Windows-basiertes Engineering-System → komplette Fabrik stillgelegt.

2. Manipulation von Sensorwerten

Angreifer verändern Messdaten → Maschinen treffen falsche Entscheidungen.

3. Sabotage über Wartungszugänge

Standardpasswörter bei Fernwartungsmodems → voller Zugriff von außen.

4. Firmware-Manipulation

Schädlicher Code in PLCs oder HMIs → unkontrollierbare Anlagenzustände.

5. Incidents über IT kompromittieren OT

Phishing, RDP, VPN-Lücken → seitliche Bewegung → OT betriebsunfähig.

Diese Szenarien bilden später Grundlagen für Übungen, Fallstudien und Prüfungsfragen.

Kapitel 3 – Architekturen & Komponenten in der OT

Operational Technology folgt eigenen architektonischen Prinzipien, technischen Restriktionen und historischen Entwicklungen. Um OT-Resilienz zu verstehen, müssen Studierende die grundlegenden Strukturen kennen, in denen industrielle Steuerungen, Sensoren, Aktoren und übergeordnete Systeme interagieren. Im Zentrum stehen bewährte Referenzmodelle wie das **Purdue-Modell** (ISA-95) sowie typische OT-Komponenten wie SCADA-Systeme, PLCs, HMIs und industrielle Kommunikationsprotokolle.

Dieses Kapitel legt die architektonischen Grundlagen und zeigt, warum OT-Resilienz nicht ohne Verständnis der zugrunde liegenden Systemschichten funktionieren kann.

3.1 Das Purdue-Modell (ISA-95) – Struktur und Bedeutung

Das **Purdue-Modell** ist das weltweit am häufigsten verwendete architektonische Referenzmodell zur Beschreibung von IT/OT-Strukturen. Es unterteilt industrielle Systeme in sechs Ebenen:

Level 0 – Physische Prozesse

- Sensoren (Temperatur, Druck, Durchfluss)
- Aktoren (Ventile, Motoren, Schalter)
- Roboter, Pumpen, Maschinen

Hier findet die **physische Realität** statt.

Level 1 – Steuerungsebene

- PLCs (Programmable Logic Controllers)
- Remote Terminal Units (RTU)
- Embedded Controller

Sie steuern direkt Sensoren und Aktoren und agieren in Echtzeit.

Level 2 – Überwachung & Kontrolle

- SCADA-Systeme
- HMI (Human Machine Interface)

- Historian-Systeme

Hier werden Prozessdaten visualisiert, Alarme angezeigt und Betriebszustände überwacht.

Level 3 – Produktionsleitsysteme

- Manufacturing Execution Systems (MES)
- Batch-Management
- Qualitätskontrolle

Sie koordinieren Produktionsabläufe und koppeln OT und Unternehmensprozesse.

Level 4 – Unternehmens-IT

- ERP-Systeme
- Supply-Chain-Management
- Business-Analytics

Verbindet OT mit betriebswirtschaftlicher Entscheidungsfindung.

Level 5 – Externe Partner / Cloud

- Fernwartungszugänge
- IIoT-Plattformen
- Predictive-Maintenance-Services
- Cloud-SCADA-Systeme

Dies ist die modernste Schicht und der größte Treiber neuer Risiken.

Warum ist das Purdue-Modell relevant für Resilienz?

- Es zeigt, **wo** Segmentierung notwendig ist.
- Es verdeutlicht Übergangsbereiche („Zone/Conduit"-Denken).
- Es hilft, Angriffs- und Ausfallpfade zu analysieren.
- Es strukturiert Notfall- und Wiederanlaufpläne.

Kurz: **Resilienz braucht Struktur – und das Purdue-Modell liefert sie.**

3.2 ICS/SCADA-Strukturen – Zentrale Elemente der OT

Industrial Control Systems (ICS) sind das Herzstück moderner OT. Sie umfassen:

SCADA (Supervisory Control and Data Acquisition)

- zentrale Überwachung
- Prozessvisualisierung
- Alarmierung
- Trend- und Historienfunktionen

DCS (Distributed Control System) Typisch für große chemische Anlagen oder Kraftwerke. Charakteristik:

- hochredundant
- verteilte Steuerlogik

- enge Kopplung von Safety und Control

PLC-basierte Systeme Flexibel einsetzbar, weit verbreitet in Fertigung, Verpackung, Logistik.

IIoT-basierte Architekturen Neue Generation:

- Cloud-Anbindungen
- Edge-Computing
- KI-basierte Mustererkennung

SCADA & ICS sind essenziell für Resilienz, da über sie sowohl Fehlfunktionen als auch Angriffe erkannt werden können.

3.3 PLCs, HMIs & Sensorik – Kernkomponenten der OT

PLCs (Programmable Logic Controllers)

- Herz der Anlagensteuerung
- Echtzeitfähig
- extrem zuverlässig
- oft proprietäre Firmware
- lange Lebenszyklen

Risiko:

Wird ein PLC manipuliert, können physische Schäden entstehen.

HMIs (Human Machine Interfaces)

- Bedienoberflächen für Anlagenfahrer
- meist Windows-basiert → anfällig für Malware
- kritisch für Resilienz, da falsche Anzeige = falsche Entscheidungen

Sensorik & Aktorik

- liefern die Grundlage aller Entscheidungen
- Fehler in Sensoren ⟹ falsche Steuerlogik
- Angriffe auf Sensoren sind selten technisch komplex, aber hochwirksam

Beispiel: Manipulierte Temperaturmesswerte → Überhitzung → Anlagenstillstand.

3.4 Historische Protokolle & Altgeräte

Viele OT-Protokolle wurden entwickelt, **bevor Cybersecurity ein Thema war**:

- Modbus
- Profibus
- DNP3
- OPC Classic
- Profinet (moderne Variante mit Security-Schichten, aber selten genutzt)

Typische Eigenschaften:

- keine Verschlüsselung

- keine Authentifizierung
- Broadcast- oder Polling-Mechanismen
- anfällig für Man-in-the-Middle-Angriffe

OT-Resilienz bedeutet deshalb oft: **Risiken managen, nicht eliminieren**, da Austausch alter Hardware Millionen kostet.

3.5 Warum Legacy-Systeme eine besondere Herausforderung sind

Vier Gründe dominieren:

1. Update-Unfähigkeit

Ein Firmware-Update kann:

- die Zertifizierung zerstören
- die Safety-Funktion beeinträchtigen
- die Produktionslinie stoppen

2. Herstellerabhängigkeit (Vendor Lock-in)

Viele Systeme brauchen:

- proprietäre Tools
- spezielle Lizenzen
- abgestimmte Firmwareversionen

3. Fehlende Sichtbarkeit

Keine Logs. Kein Monitoring.

Keine standardisierten Schnittstellen.

4. Kopplung mit Safety-Systemen

Ein Cyber-Patch kann ein Safety-Problem erzeugen — oder umgekehrt.

Diese Kombination macht OT-Resilienz zu einer Balance zwischen Sicherheit, Verfügbarkeit und Safety.

Kapitel 4 – Rollen & Verantwortlichkeiten in der OT-Resilienz

OT-Resilienz ist nicht nur eine Frage der Technik, sondern vor allem eine Frage der **Organisation**. Im Gegensatz zur klassischen IT, in der Rollen wie Administrator, Netzwerkarchitekt oder CISO etabliert sind, ist die Rollenlandschaft in der OT heterogener, historisch gewachsen und stärker durch Safety- und Betriebsanforderungen geprägt. OT-Resilienz gelingt nur dann, wenn alle beteiligten Rollen – vom Anlagenbediener bis zur Geschäftsführung – klar definierte Zuständigkeiten und abgestimmte Entscheidungswege haben.

Dieses Kapitel erläutert die wichtigsten Rollen in OT-Umgebungen, ihre Verantwortlichkeiten und die Herausforderungen, die aus der Zusammenarbeit zwischen IT- und OT-Welt entstehen.

4.1 OT-Sicherheitsverantwortlicher vs. IT-Sicherheitsverantwortlicher

Viele Organisationen verfügen über etablierte IT-Sicherheitsstrukturen, aber keine eindeutige Rolle für die OT-Security. Das führt häufig zu Missverständnissen.

IT-Sicherheitsverantwortlicher (CISO / IT-Security Manager) Typische Schwerpunkte:

- Schutz von Informationssystemen

- Governance & Policies
- IT-Risk Management
- Identity & Access Management
- Incident Response für IT-Systeme
- Einhaltung von ISO 27001 oder ähnlichen Standards

Der Fokus liegt auf **Confidentiality, Integrity & Availability (CIA)**.

OT-Sicherheitsverantwortlicher (OT-Security Engineer / ICS Security Manager) Typische Schwerpunkte:

- Schutz von Steuerungsanlagen und Maschinen
- Risikobewertung von Safety-Relevanz
- Vulnerability Management unter Betriebsbedingungen
- Sicherer Fernzugriff für Wartung
- Abstimmung von Security mit Anlagenbetrieb
- Umsetzung von Standards wie IEC 62443

Der Fokus liegt auf **Safety, Availability & Resilience**.

Warum diese Unterscheidung wichtig ist

- IT und OT folgen unterschiedlichen Prioritäten.
- Patchen ist in IT selbstverständlich, in OT oft risikoreich.
- IT-Segmente können oft neu gestartet werden, OT-Segmente meist nicht.
- Logging und Monitoring sind in IT ausgereift, in OT häufig lückenhaft.

Resilienz funktioniert nur, wenn **beide Seiten ihre Grenzen und Stärken kennen** und systematisch zusammenarbeiten.

4.2 Betreiber, Instandhaltung, Engineering, Produktion

In der OT arbeiten viele Rollen zusammen, die in IT-Umgebungen keine direkten Entsprechungen haben.

Betreiber („Operations“) Verantwortlich für:

- kontinuierlichen Betrieb der Anlagen
- Einhaltung von Sicherheitsvorschriften
- Durchführung von Routinearbeiten

Ihre Perspektive:

„Die Anlage muss laufen – heute, morgen, immer.“

Instandhaltung („Maintenance“) Verantwortlich für:

- regelmäßige Wartungsarbeiten
- Austausch defekter Komponenten
- Diagnose physischer Fehlfunktionen

Ihre Perspektive:

„Wie schnell kann ich das wieder reparieren und sicher in Betrieb nehmen?“

Engineering Verantwortlich für:

- Design neuer Anlagenabschnitte
- Integration neuer Komponenten
- Konfiguration von PLCs, SCADA-Systemen und Sensorik
- Safety-zertifizierte Änderungen

Ihre Perspektive:

„Wie kann ich den Prozess optimieren, ohne Zertifizierungen zu verlieren?“

Produktion Verantwortlich für:

- Outputmengen
- Qualität
- Liefertermine

Ihre Perspektive:

„Stillstand kostet Geld – jeder Ausfall ist kritisch.“

Warum ist das für Resilienz relevant? Weil diese Rollen andere Zielsysteme haben. Security, Safety und Produktionsziele kollidieren häufig.

Beispiel: Ein Security-Update kann zu einem Produktionsstopp führen → massive Kosten → Widerstand gegen Updates.

Eine resiliente Organisation braucht deshalb klare Entscheidungswege und abgestimmte Wartungsfenster.

4.3 Verantwortlichkeiten im Incident-Fall

Im OT-Umfeld ist ein Incident oft **zeitkritisch** und **security- UND safety-relevant**. Roles & Responsibilities müssen daher **vorher** definiert sein.

Typische Incident-Rollen in OT

- **Incident Commander (IT oder OT – je nach Ursache)**
- **OT-Operator** (überwacht Monitoring, SCADA, Alarme)
- **IT/SOC-Analyst** (analysiert Logs, Netzwerkverkehr)
- **Engineering** (bewertet mögliche Safety-Effekte)
- **Wartungstechniker** (unterstützt beim physischen Eingriff)
- **Kommunikation/Management** (interne/externe Kommunikation)

Besonderheiten im OT-Incident

1. **Die Anlage darf nicht einfach abgeschaltet werden.** Ein Shutdown kann gefährlicher sein als der Angriff.
2. **Safety hat Vorrang.**

   Fehlerszenarien müssen mit Engineering abgestimmt werden.
3. **SOC-Erkenntnisse müssen übersetzt werden.** Beispiel:

„Anomalie in Segment 3“ → Was heißt das für Pumpstation 2?

4. **Wiederanlauf ist komplexer als Wiederherstellung.**

   PLC-Sequenzen müssen in der richtigen Reihenfolge reinitialisiert werden.

4.4 CISO, SOC, CERT – Was ändert sich im OT-Kontext?

CISO

- Muss OT-Risiken strategisch berücksichtigen
- Muss mit Engineering und Betrieb eng zusammenarbeiten
- Braucht Verständnis für Safety-Prinzipien

SOC Ein klassisches SOC „sieht“ OT oft nicht, weil:

- keine Logs vorhanden sind
- proprietäre Protokolle genutzt werden
- Geräte keine Agenten unterstützen

Ein **OT-SOC** erfordert:

- passive Netzwerküberwachung (Deep Packet Inspection)
- OT-spezifische Signaturen
- Zusammenarbeit mit dem Prozessleitsystem

CERT Im OT-Kontext:

- bewertet ICS-spezifische Schwachstellen
- koordiniert OT-Incident Response
- priorisiert Risiken nach **Safety- und Verfügbarkeitskriterien**
- arbeitet eng mit Herstellern zusammen (z. B. Siemens, ABB, Rockwell)

4.5 Herausforderungen: Kultur, Sprache & Prioritäten

IT und OT sind traditionell zwei Welten. Typische Unterschiede:

Bereich	IT	OT
Ziel	Daten & Prozesse	Physische Prozesse
Priorität	Vertraulichkeit	Sicherheit & Verfügbarkeit
Wartungsfenster	häufig	selten
Lebensdauer	3–5 Jahre	10–30 Jahre
Sicherheitsphilosophie	„Patch early“	„Change as little as possible“

Diese Unterschiede erzeugen kulturelle Spannungen, die Resilienzmaßnahmen erschweren.

Warum Resilienz hier ein Organisationsprojekt ist Eine resilient arbeitende OT-Organisation benötigt:

- klare Verantwortlichkeiten
- definierte Change-Prozesse
- gemeinsame Risikobewertung (IT+OT)

- abgestimmte Kommunikationswege
- ein gemeinsames Verständnis von „kritisch“

Nur wenn diese Elemente zusammenkommen, kann OT-Resilienz ganzheitlich funktionieren.

Kapitel 5 – Bedrohungen & Angriffsvektoren in OT-Umgebungen

Operational-Technology-Systeme (OT) unterscheiden sich nicht nur technisch, sondern auch bezüglich ihrer Bedrohungslage fundamental von klassischen IT-Systemen. Während IT-Angriffe typischerweise auf Daten, Vertraulichkeit oder finanzielle Schäden abzielen, fokussieren OT-Angriffe oft auf **physische Prozesse, Produktionsausfälle und die Beeinträchtigung kritischer Infrastruktur**. OT-Resilienz muss daher Bedrohungen adressieren, die weit über klassische IT-Sicherheitsanforderungen hinausgehen.

Dieses Kapitel beschreibt typische Angriffsvektoren, reale Angriffe aus der Praxis und die spezifischen Risiken, die sich aus der Verzahnung von IT und OT ergeben.

5.1 Ransomware in OT-Umgebungen

Obwohl OT-Systeme selbst oft proprietär und schwer direkt angreifbar sind, wirken sich **Ransomware-Angriffe auf IT** dennoch massiv auf OT aus. In vielen Fällen hat der Angriff nicht die OT zum Ziel, aber die **OT fällt dennoch aus**.

Typische Angriffsmuster

- Ransomware infiltriert ein Office-Netzwerk
- Laterale Bewegung: IT → Produktionsnetz
- Engineering-Workstations oder HMI-Systeme werden verschlüsselt
- Produktionsplanungssysteme (MES/ERP) fallen aus
- Bediener können Anlagen nicht mehr steuern
- Output stoppt → Lieferketten brechen

Warum Ransomware in OT besonders gefährlich ist

- Viele Steuerungssysteme sind nicht patchbar
- HMIs sind oft Windows-basiert
- Ausfall eines Engineering-Systems kann Wiederanlauf verhindern
- Produktionsstillstand verursacht hohe Kosten pro Minute
- Safety-Prozesse können beeinträchtigt werden

Beispiel aus der Praxis Mehrere Automobilhersteller mussten in den letzten Jahren Produktionslinien stoppen, weil zentrale IT-Server verschlüsselt wurden. **Die OT war nicht kompromittiert – aber sie war unbedienbar.**

5.2 Supply-Chain-Angriffe (Manipulierte Firmware, Libraries, Drittthersteller)

OT-Systeme sind stark von Herstellern abhängig. Das macht sie anfällig für **Supply-Chain-Angriffe**.

Angriffsformen

- Manipulierte PLC-Firmware
- kompromittierte Wartungslaptops von Dienstleistern
- Schadcode in Engineering-Software

- Backdoors in industriellen Routern
- infizierte Vendor-Updates

Warum OT besonders betroffen ist

- Komponenten kommen häufig aus spezialisierten Lieferketten
- Geräte werden selten ersetzt oder aktualisiert
- Firmware ist proprietär und schwer zu verifizieren
- Zulieferer haben oft Remote-Zugänge (VPN/Modem)

Praxisbeispiel: Stuxnet Stuxnet manipulierte Siemens-S7-Steuerungen über infizierte Engineering-Software. Der Angriff hat gezeigt, dass OT-Firmware ein strategischer Angriffsvektor ist.

5.3 Remote Access & Wartungszugänge

OT benötigt regelmäßige Wartung durch Hersteller oder externe Dienstleister. Diese Wartungszugänge sind einer der häufigsten Einfallstore.

Typische Schwachstellen

- Fernwartungsmodems mit Standardpasswörtern
- schlecht geschützte VPN-Zugänge
- gemeinsam genutzte Dienstleisterkonten
- fehlende Protokollierung der Remote-Aktivitäten
- immer aktive, dauerhaft verbundene Leitungen

Warum kritisch? Remote Access erlaubt direkten Zugriff auf:

- SCADA-Systeme
- PLC-Programmierung
- Firmware-Updates
- Parametrierung von Safety-Systemen

Ein unautorisierter Zugriff kann zu **sofortigen, physischen Effekten** führen.

5.4 Manipulation von Steuerlogik und Prozessparametern

Einer der gefährlichsten Angriffsvektoren in OT-Systemen ist die Manipulation von:

- PLC-Programmen
- SCADA-Anzeigen
- Alarmunterdrückung
- Sollwerten (z. B. Temperatur, Druck, Drehzahl)
- Sicherheitsinterlocks

Warum dieser Angriffsvektor existiert

- PLCs sind oft ohne Authentifizierung programmierbar
- keine Versionskontrolle bei Logikänderungen
- ungesicherte Netzwerke erleichtern MITM-Angriffe

- Operatoren verlassen sich auf Visualisierungen

Praxisbeispiel: Triton/Trisis Angreifer manipulierten ein Safety-Instrumented System (SIS), mit dem Ziel, physische Schäden zu verursachen.

Dies zeigt die **gefährlichste Kategorie von OT-Angriffen**:

Angriffe, die Safety aushebeln, um physische Zerstörung zu ermöglichen.

5.5 Physische Sabotage und Insider-Bedrohungen

Im OT-Kontext spielen **physische Angriffe** eine wesentlich größere Rolle als in der IT.

Beispiele

- Sabotage durch unzufriedene Mitarbeiter
- Manipulation von Sensoren (z. B. Sabotage an Türkontakten)
- Beeinflussung von Not-Aus-Schaltern
- Gefälschte Geräte, die in Anlagen eingeschleust werden
- Techniker, die Schadsoftware auf Laptops mitbringen

Warum Insider-Angriffe so gefährlich sind

- Insider kennen Anlagenlogik
- sie besitzen Zugang und Vertrauen
- sie können Safety-Systeme verstehen und umgehen

OT-Resilienz erfordert deshalb nicht nur Cyber-Schutz, sondern auch **strikte physische Kontrolle**.

5.6 Kompromittierung über IT – Der IT→OT-Pfadeffekt

Der häufigste Weg in die OT ist **nicht die OT selbst**, sondern die IT.

Typische Angriffskette

1. Phishing / Malware / RDP-Schwachstelle in IT
2. Angreifer bewegt sich lateral durch das Netzwerk
3. Übergang über schlecht segmentierte Zonen
4. Zugriff auf Engineering-Workstations
5. Manipulation oder Abschaltung von OT-Funktionen

Warum der Übergang so gefährlich ist

- IT-Security betrachtet OT oft nicht ausreichend
- Firewall-Regeln sind historisch gewachsen
- Produktionsdruck führt zu Ausnahmen („Wir öffnen kurz den Port…“)
- Logging endet oft am IT/OT-Übergang

Praxisbeispiel: Colonial Pipeline (2021) Angriff begann in der IT → Management stoppte OT-Betrieb aus Vorsorge → Treibstoffversorgung an der US-Ostküste fiel aus.

Dies zeigt: **IT-Schwachstellen können OT zum Stillstand bringen, selbst wenn OT nicht kompromittiert ist.**

Kapitel 6 – Resilienzmaßnahmen für OT

Operational-Technology-Systeme unterscheiden sich technisch und organisatorisch stark von klassischer IT. Daher müssen Resilienzmaßnahmen speziell für OT angepasst werden. Ziel ist es nicht, alle Risiken zu eliminieren – das wäre aufgrund veralteter Geräte, fehlender Updatefähigkeit und Safety-Anforderungen unrealistisch. Vielmehr geht es darum, **Risiken zu verringern**, **Angriffe zu erkennen**, **physische Auswirkungen zu verhindern** und **den Wiederanlauf zu gewährleisten**.

Dieses Kapitel gliedert Resilienzmaßnahmen in drei Bereiche:

1. **Organisatorische Maßnahmen**
2. **Technische Maßnahmen**
3. **Integration von Safety & Security**

6.1 Organisatorische Maßnahmen

Organisatorische Resilienz ist in der OT mindestens so wichtig wie technische. Viele OT-Vorfälle eskalieren nicht, weil die Technik versagt, sondern weil Verantwortlichkeiten unklar sind oder Prozesse fehlen.

1. OT-spezifische Governance

OT braucht **eigene Policies**, die den Besonderheiten gerecht werden:

- keine ungeplanten Änderungen an Steuerlogiken
- definierte Update- und Patchfenster
- Regeln für Fernwartung
- Zutritts- und Zugangsrichtlinien für Servicepersonal
- klare Dokumentation aller Netzwerke und Steuerungsebenen

OT-Governance darf nicht einfach aus der IT kopiert werden.

2. Klare Verantwortlichkeiten und Rollen

Resiliente Organisationen definieren:

- Wer darf eine PLC umprogrammieren?
- Wer genehmigt Änderungen an Safety-Systemen?
- Wer beurteilt Risiken bei Patches?
- Wer entscheidet im Notfall über einen Anlagenstopp?

Ohne klare Entscheidungswege kommt es im Incident-Fall zu Verzögerungen — und Verzögerungen können in OT gefährlich werden.

3. Change-Management für OT

Änderungen an OT-Systemen können Safety-Funktionen beeinflussen. Daher:

- Kein Patch ohne Risikoanalyse
- Kein Firmware-Update während laufender Produktion
- Änderungen nur mit dokumentierter Freigabe
- Engineering-Änderungen werden versioniert und archiviert
- „Rollback“-Strategien müssen existieren

OT-Change-Management ist konservativ, aber notwendig.

4. Asset-Inventar & Dokumentation

In OT ist Sichtbarkeit entscheidend.

Ein resilientes OT-System kennt:

- alle PLCs, HMIs, Sensoren
- Firmware-Versionen
- Netzsegmente und Ports
- Safety-Abhängigkeiten
- Kommunikationsbeziehungen

Viele OT-Incidents eskalieren, weil niemand weiß, **welche Komponenten überhaupt existieren**.

5. Trainings & Awareness

OT-Personal ist oft exzellent in Betrieb und Safety geschult, aber nicht in Cybersecurity.

Wichtige Trainingsinhalte:

- Social Engineering
- Auswirkungen von Cyberangriffen auf Safety
- Reaktion auf Anomalien
- sichere Nutzung von Fernwartungszugängen

Resilienz entsteht nicht nur durch Technik, sondern durch **geschultes Verhalten**.

6.2 Technische Maßnahmen

Technische Resilienz muss im OT-Umfeld angepasst werden: Sie wirkt stärker präventiv und kompensatorisch, weil viele Systeme nicht gepatcht oder isoliert abgeschaltet werden können.

1. Netzwerksegmentierung & Zonenmodell

Segmentierung ist eine Kernmaßnahme, z. B. nach ISA/IEC 62443:

- OT wird in **Zonen** unterteilt
- Zonen sind durch **Conduits (definierte Übergänge)** verbunden
- OT und IT sind strikt getrennt
- Engineering-Arbeitsplätze sind besonders geschützt
- SCADA-Netzwerke haben eigene Firewalls

Je kleiner eine Zone, desto begrenzter der Schaden.

2. Jump Hosts & kontrollierter Fernzugriff

Fernwartung ist unverzichtbar. Resilient wird sie durch:

- zentralisierte Jump Hosts
- Multi-Faktor-Authentifizierung
- zeitlich begrenzte Wartungsfenster
- Session-Recording
- Deaktivierung von permanenten VPN-Tunneln

- Keine direkten Verbindungen von Dienstleistern ins OT-Netz

Jeder Zugang ist ein Risiko — kontrollierte Zugänge sind Resilienz.

3. Monitoring & OT-SIEM

OT-Sichtbarkeit ist traditionell gering. Moderne OT-Resilienz nutzt:

- passive Netzwerküberwachung (tap/mirror)
- Deep Packet Inspection für OT-Protokolle
- Machine Learning zur Mustererkennung
- Alarmierung bei untypischen Prozessflüssen
- Integritätsüberwachung von PLC-Programmen

Ein SOC ohne OT-Transparenz ist blind.

4. Patch-Management unter OT-Bedingungen

In der OT gilt:

- „So wenig wie möglich ändern, aber so viel wie nötig."

Resilienzstrategien:

- Patches erst im Testsystem validieren
- Risikoabwägung zwischen Cyberrisiko und Produktionsrisiko
- klare Minimierungsstrategien (Compensating Controls)
- Zeitfenster für Updates langfristig planen

Viele Cybervorfälle resultieren aus fehlenden Patches — viele OT-Ausfälle aus *falsch* gesetzten Patches.

Der Balanceakt **ist** Resilienz.

5. Backup & Wiederherstellung

OT-Backups unterscheiden sich von klassischen IT-Backups.

Backup-Objekte:

- PLC-Programme
- SCADA-Konfigurationen
- Historian-Daten
- HMI-Konfigurationen
- Netzwerkgeräte (Switches/Firewalls)
- Safety-Konfigurationen

Wichtig:

Backups müssen **offline**, **versioniert** und **getestet** sein.

6. Redundanz & Ausfallkonzepte

Typische Resilienzmechanismen:

- redundante Steuerungen
- Hot-Standby-Systeme

- Duale Netzwerktopologien
- USVs & Notstromsysteme
- gespiegelte Datenpfade

Redundanz schützt nicht nur gegen Ausfälle, sondern auch gegen Angriffe.

6.3 Safety & Security Integration

OT-Resilienz kann nur funktionieren, wenn **Safety** und **Security** gemeinsam gedacht werden. Beide Systeme schützen unterschiedliche Aspekte, sind aber eng miteinander verknüpft.

1. Gemeinsames Risikomanagement

Ein erfolgreicher OT-Angriff kann Safety-Funktionen direkt beeinflussen:

- Überdruck
- unkontrollierte Ventilsteuerung
- Abschaltung kritischer Pumpen

Risikomodelle müssen diese Kopplung berücksichtigen.

2. Hazard Analysis + Cyber Threat Analysis

Moderne Anlagen kombinieren:

- klassische Hazard Analysis (HAZOP)
- Cyber Threat Modeling

Beispiel:

Ein Sensorfehler kann physisch ausfallen **oder** durch Cybermanipulation entstehen — die Auswirkungen sind vergleichbar.

3. Safety Integrity Levels (SIL) & Security Levels (SL)

SIL (Safety Integrity Level):

gibt an, wie zuverlässig ein Safety-System funktioniert.

SL (Security Level) aus IEC 62443:

gibt an, wie widerstandsfähig ein System gegen Cyberangriffe ist.

Resilienz bedeutet:

- Safety schützt gegen zufällige Fehler
- Security schützt gegen absichtliche Angriffe
- zusammen ergeben sie Systemresilienz

4. Kommunikationskultur zwischen IT, OT und Safety

Resilienz entsteht, wenn:

- IT die Safety-Prioritäten versteht
- OT die Sicherheitsrisiken versteht
- Safety die Bedeutung von Security anerkennt

Viele Organisationen scheitern nicht an Technik, sondern an **Kommunikation**.

Kapitel 7 – Notfallmanagement & Wiederanlauf in der OT

Notfallmanagement in OT-Umgebungen unterscheidet sich grundlegend vom Incident Management klassischer IT-Systeme. Während IT-Systeme oft relativ gefahrlos heruntergefahren, neu gestartet oder isoliert werden können, beeinflussen OT-Systeme **reale physische Prozesse**, bei denen ein falscher Eingriff zu erheblichen Schäden führen kann. Deshalb erfordern OT-Notfälle eine Kombination aus technischer Expertise, Safety-Know-how, klar definierten Rollen und detaillierten Wiederanlaufplänen.

Dieses Kapitel beschreibt, wie Organisationen sich auf OT-Notfälle vorbereiten, wie ein sicherer Wiederanlauf organisiert wird und welche Besonderheiten OT-Incidents von IT-Incidents unterscheiden.

7.1 Besonderheiten im OT-Krisenfall

Ein Notfall in OT (z. B. ein Cyberangriff, ein Anlagenfehler oder ein gefährlicher Prozesszustand) ist **komplexer** als in der IT. Gründe dafür:

1. OT kann nicht einfach abgeschaltet werden

Ein sofortiger Shutdown ist oft gefährlicher als Weiterbetrieb:

- Pumpen dürfen nicht abrupt stoppen
- Druck und Temperatur müssen kontrolliert abgebaut werden
- Chemische Prozesse müssen geordnet auslaufen
- Roboterbewegungen müssen definiert zum Stillstand kommen

Ein ungeplanter Stopp kann Menschen gefährden oder Anlagen beschädigen.

2. Safety hat Vorrang

Jedwede Maßnahme — ob technisch oder organisatorisch — muss zuerst darauf geprüft werden, ob sie:

- Anlagen sicher hält
- Personen nicht gefährdet
- Umweltauflagen erfüllt

Ein CISO alleine kann diese Entscheidung nicht treffen. Engineering und Safety müssen eingebunden sein.

3. Incident-Diagnose ist schwieriger

Typische Herausforderungen:

- Keine Logs oder Telemetrie
- Proprietäre Steuerungsprotokolle
- Komplexe Wechselwirkungen zwischen Maschinen
- Sichtbare Symptome verraten nicht die Root Cause

Beispiel: Eine Pumpe steht still. Ursache kann sein:

- Manipulierte Steuerlogik
- Überhitzung
- Kommunikation unterbrochen
- Angreifer im Netzwerk
- Safety-Shutdown ausgelöst

OT-Resilienz erfordert systematische Diagnose.

4. Wiedereinschalten ist gefährlicher als Abschalten

Ein „Cold Start" einer Anlage kann neue Risiken erzeugen:

- initialer Druckaufbau
- Maschinen referenzieren sich neu
- Sensoren müssen synchronisiert werden
- Safety-Systeme führen Selbsttests durch

Deshalb sind Wiederanlaufpläne entscheidend.

7.2 OT-spezifische Incident Response

Eine Incident-Response-Strategie für OT folgt einem ähnlichen Ablauf wie in der IT, aber mit wichtigen Anpassungen.

1. Erkennen & Alarmierung

Besonderheiten:

- SCADA-Alarme
- Prozessanomalien (z. B. ungewöhnliche Druckwerte)
- Netzwerk-IDS für OT-Protokolle
- Hinweise von Bedienern („HMI zeigt Unfug an")

2. Erste Bewertung (triage)

Wichtige Fragen:

- Gibt es Auswirkungen auf Safety?
- Gibt es Auswirkungen auf den Prozess?
- Kann die Anlage weiterlaufen?
- Muss Engineering sofort eingebunden werden?

3. Stabilisierung

Ziel: den Prozess in einen **sicheren Zustand** überführen, nicht unbedingt den Angriff sofort stoppen.

Beispiele:

- Parameter auf sichere Werte setzen
- Redundanz aktivieren
- Prozesse geordnet herunterfahren
- betroffene Steuerungen isolieren

4. Forensik & Analyse

Besonderheiten in OT:

- keine Eingriffe, die Safety beeinflussen
- keine Neustarts ohne Engineering-Freigabe
- forensische Sicherung muss passiv erfolgen

- Änderungen dürfen Prozesse nicht stören

Forensische Maßnahmen sind oft eingeschränkt — Resilienz ersetzt Forensik.

5. Kommunikation

Wesentliche Stakeholder:

- Anlagenfahrer
- Produktion
- Safety-Verantwortliche
- Management
- ggf. Behörden (insb. KRITIS)

Kommunikation muss präzise, abgestimmt und schnell erfolgen.

6. Wiederherstellung & Wiederanlauf

Technische Wiederherstellung ist nur der erste Schritt.

Der **Wiederanlauf** ist meist der riskante Teil.

7.3 Wiederanlaufplanung: Cold, Warm und Hot Start

OT-Anlagen verwenden verschiedene Wiederanlaufmethoden, abhängig von Risiko, Prozess und Architektur.

1. Cold Start

Vollständiger Neustart einer Anlage oder Steuerung.

Merkmale:

- hoher Aufwand
- hohes Risiko (Neusynchronisierung aller Sensoren/Aktoren)
- nur möglich, wenn Prozesse stehen
- notwendig nach schwerem Incident

2. Warm Start

Teilweiser Neustart mit Erhalt von Prozesszuständen.

Merkmale:

- geringeres Risiko
- schnellere Rückkehr in den Betrieb
- oft nach geordnetem Shutdown verfügbar

3. Hot Start / Failover

Redundante Steuerungssysteme übernehmen automatisch.

Merkmale:

- geringste Ausfallzeit
- ideal für kritische Prozesse
- muss regelmäßig getestet werden

Beispiel:

Switch-over von primary PLC auf redundant PLC bei Störung.

7.4 Koordination mit Produktion & Engineering

OT-Notfallmanagement ist ein **interdisziplinäres Teamprojekt**.

Produktion

- bewertet Auswirkungen auf Output
- entscheidet über Produktionsstopps
- stellt Personal zur Überwachung bereit

Engineering

- analysiert Steuerlogik
- beurteilt Safety-Auswirkungen
- entscheidet über Wiederanlauf

IT & SOC

- analysiert Netzwerkdaten
- isoliert betroffene Segmente
- überwacht für weitere Angriffe

Wartung / Maintenance

- stellt physische Eingriffe sicher
- prüft Sensoren und Hardware

Resilienz entsteht nur, wenn diese Gruppen **synchron arbeiten**.

7.5 Lessons Learned aus realen OT-Incidents

Aus Vorfällen der letzten Jahre ergeben sich zentrale Erkenntnisse:

1. Prozesse müssen dokumentiert sein

Fehlende Wiederanlaufpläne verzögern die Rückkehr in den Betrieb erheblich.

2. Redundanz rettet Anlagen

Hot-Standby-Systeme verhindern physische Schäden im Störfall.

3. Kommunikation muss geübt werden

Missverständnisse zwischen IT, OT und Produktion kosten Zeit — und erzeugen Risiken.

4. Forensik ist eingeschränkt

In OT bleibt wenig Zeit und wenig Spielraum für tiefgehende Analytik.

5. Übung macht den Unterschied

Regelmäßige Notfalltests („Fire Drills“) verbessern die Reaktionsfähigkeit massiv.

Kapitel 8 – Normen, Standards & Best Practices für OT-Resilienz

Während die klassische IT-Sicherheit häufig durch ISO 27001, NIST oder BSI-Grundschutz geprägt ist, existiert für OT ein eigenes Ökosystem an Normen, Leitfäden und Best Practices. Diese Standards sind wichtig, weil OT-Umgebungen sehr heterogen, oft jahrzehntealt und sicherheitskritisch sind. Sie helfen

Organisationen dabei, Resilienz systematisch zu planen, umzusetzen und zu überprüfen – auch dann, wenn die technischen Möglichkeiten begrenzt sind.

Dieses Kapitel stellt die wichtigsten Standards vor, ordnet sie in den Kontext der OT-Resilienz ein und erklärt, wie sie in der Praxis angewendet werden.

8.1 IEC 62443 – Der wichtigste internationale Standard für OT-Security

Die **IEC 62443** ist der umfassendste und global am weitesten verbreitete Standard für industrielle Sicherheit. Sie wurde speziell für OT-Systeme entwickelt und deckt Technik, Prozesse und Organisation ab.

Kernprinzipien der IEC 62443

- **Defense-in-Depth:** mehrschichtige Schutzmaßnahmen
- **Zonen & Conduits:** Segmentierung als zentrales Architekturprinzip
- **Risikoorientierung:** Security Level (SL 1–4)
- **Rollenorientiert:** berücksichtigt Hersteller, Integratoren und Betreiber

Aufbau der Norm

- **62443-1-x:** Begriffe, Modelle, Grundlagen
- **62443-2-x:** Managementsysteme (ähnlich zu ISO 27001, aber OT-spezifisch)
- **62443-3-x:** Systemarchitektur & Zonenmodell
- **62443-4-x:** Anforderungen an Komponenten (z. B. PLCs, HMIs, RTUs)

Warum wichtig für OT-Resilienz?

- Verbindet Safety und Security
- Lösung für Legacy-Umgebungen (kompensierende Maßnahmen)
- Grundlage für Zertifizierungen (z. B. SL-zertifizierte Komponenten)
- Industriestandard in Energie, Chemie, Fertigung, Transport, Wasserwirtschaft

Fazit: IEC 62443 ist der OT-Goldstandard. Jede Resilienzstrategie sollte sich daran orientieren.

8.2 NIST Frameworks für industrielle Systeme (NIST CSF & NIST 800-82)

Das **NIST Cybersecurity Framework (CSF)** und vor allem das Dokument **NIST SP 800-82** bieten praxisnahe Leitlinien für ICS-/OT-Sicherheit.

NIST CSF – 5 Kernfunktionen

- **Identify**
- **Protect**
- **Detect**
- **Respond**
- **Recover**

Dieses Modell eignet sich hervorragend, um OT-Resilienz organisatorisch zu strukturieren.

> **i** Hinweis zur Aktualität
>
> Das NIST Cybersecurity Framework 2.0 (2024) ergänzt „Govern“ als sechste Kernfunktion [1]. Siehe Quellen, Hinweis 7.

NIST SP 800-82 – Guide to Industrial Control Systems Security

> **i** Hinweis zur Aktualität
>
> Die aktuelle Revision 3 von NIST SP 800-82 (2023) heißt „Guide to Operational Technology (OT) Security“ [2]. Siehe Quellen, Hinweis 8.

Schwerpunkte:

- typische ICS-Architekturen
- ICS-spezifische Bedrohungen
- Best Practices für Netzwerksegmentierung
- Vorgehensmodelle für Incident Response in OT

Warum wichtig?

- sehr verständlich, ideal für Ausbildung
- starke Praxisorientierung
- Grundlage für viele internationale Unternehmen

Fazit: NIST ist didaktisch hervorragend und ergänzt IEC 62443 auf Managementebene.

8.3 BSI ICS-Kompendium & BSI 200-4 Notfallmanagement

Für Deutschland sind die Veröffentlichungen des **Bundesamtes für Sicherheit in der Informationstechnik (BSI)** zentral.

BSI ICS-Security-Kompendium Beinhaltet:

- typische OT-Komponenten
- Angriffsvektoren
- Schutzmaßnahmenkatalog
- Fallstudien und Beispiele

Es ist besonders relevant für:

- Energiebranche
- Wasserwirtschaft
- Kommunale Infrastruktur
- Fertigung & Maschinenbau

BSI 200-4 – Modernes Notfallmanagement Beschreibt ein strukturiertes Vorgehen für Notfallvorsorge und Krisenmanagement, inklusive:

- Notfallhandbuch

- Wiederanlaufplanung
- Notfallübungen
- Lessons Learned

Für OT-Resilienz ist 200-4 wichtig, weil sie Wiederherstellung und Betriebssicherheit verbindet.

Fazit: Für deutsche Betreiber – insbesondere KRITIS – sind diese Dokumente Pflichtlektüre.

8.4 ENISA – Empfehlungen für OT & kritische Infrastrukturen

Die **EU-Agentur für Cybersicherheit (ENISA)** veröffentlicht regelmäßig Analysen, Reports und Best Practices für:

- kritische Infrastrukturen
- industrielle Automatisierung
- Energie- & Smart-Grid-Sicherheit
- Supply-Chain-Risiken
- Resilienzbewertungen auf europäischer Ebene

Wichtige Beiträge:

- **Good Practices for Industrial Control Systems Security**
- **Threat Landscape for Critical Infrastructure**
- Empfehlungen zur NIS-2-Umsetzung

Rolle für OT-Resilienz

- Europäische Perspektive
- Orientierung für Betreiberpflichten (z. B. bei NIS-2)
- Fokus auf Resilienz statt klassischer Security

Fazit: ENISA verbindet Technik, Governance und EU-Regulierung.

8.5 ISO 27019 – Energiespezifischer OT-Sicherheitsstandard

ISO/IEC **27019** ist eine branchenspezifische Norm für Energiesysteme (Erzeugung, Übertragung, Verteilung).

Sie basiert auf ISO 27002, ergänzt um OT-Bedarf:

- Schutz von Leitwarten
- Steuerungen von Turbinen, Transformatoren, Kraftwerken
- Risiken durch Smart-Grid-Komponenten
- Umgang mit Fernwirktechnik

Fazit: Relevanz insbesondere für Strom- und Gasnetzbetreiber.

8.6 Zusammenspiel mit ISO 27001 & BSI Grundschutz

Viele Unternehmen starten mit ISO 27001 oder BSI Grundschutz als generischer Sicherheitsstandard. Für OT reicht das jedoch nicht aus.

Warum? ISO 27001 adressiert primär:

- Informationssicherheit
- IT-Prozesse
- IT-Risiken

OT benötigt zusätzlich:

- Safety-Integration
- Risikobewertungen für physische Prozesse
- Systeme, die nicht patchbar sind
- spezifische Netzwerkzonen
- Wiederanlaufplanung statt Restore

Wie kombiniert man die Standards sinnvoll?

1. **ISO 27001 / Grundschutz:** für Managementsystem & Organisation
2. **IEC 62443:** für technische Umsetzung in OT
3. **NIST / ENISA:** als Ergänzung für Methoden und Best Practices
4. **BSI 200-4:** für Notfall- und Wiederanlaufmanagement

Fazit: Resilienz entsteht erst durch die Verbindung der Standards, nicht durch den Einsatz eines einzelnen.

Kapitel 9 – KI in OT-Umgebungen: Chancen & Risiken

Künstliche Intelligenz (KI) hält zunehmend Einzug in Operational-Technology-Umgebungen. Sie verspricht effizientere Prozesse, frühere Fehlererkennung und optimierte Wartung. Gleichzeitig bringt der Einsatz von KI in OT neue Risiken mit sich, da Fehlentscheidungen oder Manipulationen nicht nur digitale, sondern **physische Auswirkungen** haben können. OT-Resilienz muss diese Chancen nutzen, ohne neue systemische Verwundbarkeiten zu schaffen.

Dieses Kapitel ordnet KI im OT-Kontext ein, beschreibt typische Anwendungsfälle, analysiert Risiken und verbindet sie mit den zuvor behandelten Resilienzprinzipien.

9.1 Einsatzfelder von KI in OT-Umgebungen

KI wird in OT nicht primär für autonome Entscheidungen eingesetzt, sondern vor allem als **unterstützendes Analyse- und Prognoseinstrument**.

1. Predictive Maintenance

KI analysiert Sensordaten, um:

- Verschleiß frühzeitig zu erkennen
- Ausfälle vorherzusagen
- Wartungsintervalle zu optimieren

Beispiele:

- Schwingungsanalyse von Motoren
- Temperaturprofile von Lagern
- Stromaufnahme von Antrieben

Nutzen:

- geringere Stillstandzeiten
- planbare Wartung
- höhere Anlagenverfügbarkeit

2. Anomalieerkennung in Prozessdaten

KI-Modelle erkennen:

- Abweichungen von Normalzuständen
- schleichende Fehlfunktionen
- ungewöhnliche Prozessmuster

Im Unterschied zu klassischen Schwellenwerten erkennt KI auch **nicht-lineare Zusammenhänge**, die für Menschen schwer erkennbar sind.

3. Qualitätskontrolle

Einsatz z. B. bei:

- optischer Inspektion (Kameras + KI)
- Mustererkennung auf Produktionslinien
- Klassifikation fehlerhafter Produkte

Hier wirkt KI direkt auf Produktionsentscheidungen, allerdings meist **ohne unmittelbaren Safety-Impact**.

4. Energie- und Prozessoptimierung

KI wird eingesetzt zur:

- Optimierung von Energieverbrauch
- Lastverteilung
- Reduktion von Ausschuss
- Prozessstabilisierung

Diese Anwendungsfälle sind wirtschaftlich attraktiv, aber kritisch, wenn KI Entscheidungen automatisiert trifft.

9.2 KI-basierte Anomalieerkennung: Chancen für Resilienz

KI kann die OT-Resilienz deutlich stärken, wenn sie richtig eingesetzt wird.

Resilienzgewinne

- Frühzeitige Erkennung von Störungen
- Erkennen subtiler Prozessabweichungen
- Unterstützung von Bedienern
- Reduzierung ungeplanter Ausfälle

KI fungiert hier als **„Frühwarnsystem“**.

Grenzen

- KI ersetzt keine Safety-Systeme
- KI darf nicht alleinige Entscheidungsinstanz sein
- Ergebnisse müssen interpretierbar sein

In resilienten OT-Architekturen bleibt der Mensch oder das Safety-System die letzte Instanz.

9.3 Risiken durch KI in OT-Systemen

Die Einführung von KI schafft neue Angriffs- und Fehlerquellen.

1. Fehlentscheidungen und Modellfehler

KI lernt aus historischen Daten. Probleme entstehen, wenn:

- Trainingsdaten unvollständig oder verzerrt sind
- Prozessänderungen nicht im Modell abgebildet sind
- seltene, aber kritische Szenarien fehlen

In OT kann eine falsche Empfehlung:

- Anlagen beschädigen
- Prozesse destabilisieren
- Safety-Risiken erzeugen

2. Daten-Poisoning

Angreifer manipulieren Trainingsdaten oder Sensordaten, um:

- falsche Anomalien zu erzeugen
- echte Anomalien zu verschleiern
- Wartung zu verzögern oder auszulösen

Beispiel: Manipulierte Vibrationsdaten → KI erkennt keinen Lagerschaden → Totalausfall.

3. Modellmanipulation & Supply-Chain-Risiken

KI-Modelle stammen häufig von:

- externen Dienstleistern
- Cloud-Plattformen
- Herstellern von OT-Software

Risiken:

- nicht überprüfbarer Trainingsprozess
- Black-Box-Modelle
- fehlende Update-Transparenz

4. Abhängigkeit von Cloud & IT-Infrastruktur

Viele KI-Lösungen sind:

- cloudbasiert
- abhängig von stabiler IT-Konnektivität
- kostenabhängig (API-Nutzung, Credits)

Ein Ausfall oder Angriff auf IT- oder Cloud-Komponenten kann damit **indirekt OT-Funktionen beeinträchtigen**.

9.4 KI-Resilienz in OT: Übertragung der Resilienzprinzipien

Die in der Vorlesung behandelten KI-Resilienzprinzipien gelten auch im OT-Kontext – allerdings verschärft.

1. Human-in-the-Loop

- KI unterstützt, entscheidet aber nicht allein
- Kritische Eingriffe müssen freigegeben werden
- Safety-Systeme bleiben unabhängig

2. Transparenz & Nachvollziehbarkeit

- KI-Ergebnisse müssen erklärbar sein
- Black-Box-Modelle sind kritisch
- Bediener müssen verstehen, *warum* eine Empfehlung erfolgt

3. Redundanz & Plausibilitätsprüfungen

- KI-Ergebnisse werden gegen klassische Verfahren geprüft
- Abweichungen lösen Prüfungen aus, keine Aktionen

4. Monitoring & kontinuierliche Validierung

- Modelle altern („Model Drift“)
- Prozessänderungen erfordern Re-Training
- KI-Performance muss überwacht werden

5. Klare Abgrenzung von Safety-Systemen

- KI darf Safety-Logik nicht ersetzen
- Not-Aus-Systeme müssen unabhängig bleiben
- KI darf Safety-Mechanismen nicht deaktivieren

9.5 Verbindung von KI-, IT- und OT-Resilienz

KI in OT wirkt als **Brückentechnologie**:

- Sie verbindet IT-Infrastruktur, Cloud-Services und OT-Prozesse
- Sie erhöht die Komplexität des Gesamtsystems
- Sie erfordert integrierte Resilienzstrategien

OT-Resilienz der Zukunft bedeutet:

- KI bewusst einsetzen
- Risiken verstehen
- Sicherheits- und Safety-Grenzen respektieren
- KI als Assistenz, nicht als Autonomie begreifen

Zwischenfazit KI kann OT-Resilienz stärken, wenn:

- sie kontrolliert eingesetzt wird

- sie transparent und erklärbar ist
- sie organisatorisch eingebettet ist
- sie technisch abgesichert ist

Unkontrollierter KI-Einsatz erzeugt neue systemische Risiken — besonders in sicherheitskritischen Umgebungen.

Kapitel 10 – Übungen & Fallstudien zur OT-Resilienz

OT-Resilienz lässt sich nicht allein theoretisch verstehen. Die Komplexität industrieller Systeme, die Wechselwirkungen zwischen IT, OT und Safety sowie die realen Auswirkungen von Störungen erfordern **anwendungsorientiertes Lernen**. Übungen und Fallstudien helfen Studierenden, abstrakte Resilienzkonzepte auf reale Szenarien zu übertragen und typische Entscheidungssituationen zu durchdenken.

Dieses Kapitel bündelt praxisnahe Fallbeispiele und Übungsformate, die zentrale Inhalte der vorherigen Kapitel integrieren.

10.1 Fallstudie: Cyberangriff auf ein SCADA-System

Ausgangslage

Ein mittelständischer Produktionsbetrieb betreibt eine automatisierte Fertigungsstraße. Die Anlage besteht aus:

- mehreren PLCs
- einem zentralen SCADA-System
- Engineering-Workstations
- einem Übergang zur Unternehmens-IT (ERP/MES)

Eines Morgens meldet das SCADA-System:

- verzögerte Rückmeldungen
- inkonsistente Sensorwerte
- sporadische Kommunikationsabbrüche

Gleichzeitig berichten Bediener über ungewöhnliche Anzeigen an den HMIs.

Aufgabenstellung

1. Identifizieren Sie mögliche Ursachen des Vorfalls.
2. Ordnen Sie den Vorfall in das Purdue-Modell ein.
3. Welche Bedrohungsvektoren aus Kapitel 5 kommen in Frage?
4. Welche ersten Maßnahmen wären im Sinne der OT-Resilienz sinnvoll?
5. Welche Rollen müssen in die Incident Response eingebunden werden?

Lernziel Die Studierenden sollen:

- typische OT-Incident-Symptome erkennen
- IT- und OT-Perspektiven unterscheiden
- Resilienz vor Forensik priorisieren
- Sicherheits- und Safety-Aspekte gemeinsam bewerten

10.2 Analyse eines realen OT-Vorfalls: Triton/Trisis

Kurzbeschreibung

Beim Triton/Trisis-Angriff wurde ein Safety-Instrumented System (SIS) gezielt manipuliert. Ziel war nicht nur der Produktionsausfall, sondern potenziell die **Gefährdung von Menschenleben**.

Aufgabenstellung

1. Welche Besonderheit unterscheidet diesen Angriff von klassischer Malware?
2. Welche Rolle spielt Safety im Kontext dieses Angriffs?
3. Welche organisatorischen Schwächen wurden ausgenutzt?
4. Welche Resilienzmaßnahmen hätten den Schaden begrenzen können?
5. Welche Lehren lassen sich für zukünftige OT-Architekturen ziehen?

Lernziel

- Verständnis für hochentwickelte OT-Angriffe
- Einordnung von Safety und Security
- Sensibilisierung für gezielte, staatliche Angreifer
- Ableitung konkreter Resilienzmaßnahmen

10.3 Rollenspiel: CISO vs. Produktionsleiter

Szenario

Nach einem Sicherheitsvorfall fordert der CISO:

- sofortige Segmentierung
- Abschaltung eines Fernwartungszugangs
- Notfall-Patching

Der Produktionsleiter warnt:

- vor Produktionsausfall
- vor Lieferverzug
- vor Vertragsstrafen

Aufgabenstellung Studierende schlüpfen in unterschiedliche Rollen:

- CISO
- Produktionsleitung
- OT-Engineer
- Safety-Beauftragter

Ziel ist es, eine gemeinsame Entscheidung zu treffen.

Lernziel

- Verständnis für Zielkonflikte
- Förderung interdisziplinärer Kommunikation
- Anwendung von Resilienzdenken statt Maximal-Security

- Entwicklung tragfähiger Kompromisse

10.4 Übung: Entwicklung eines Zone-Conduit-Modells

Aufgabenstellung

Auf Basis einer vereinfachten Produktionsanlage sollen Studierende:

1. Zonen gemäß IEC 62443 definieren
2. Conduits zwischen den Zonen festlegen
3. kritische Übergänge identifizieren
4. Schutzmaßnahmen pro Zone benennen

Lernziel

- Praktisches Verständnis für Segmentierung
- Anwendung des Purdue-Modells
- Identifikation von Angriffspfaden
- Übertragung von Standards in konkrete Architekturentscheidungen

10.5 Übung: Erstellung eines OT-Wiederanlaufplans

Szenario

Nach einem OT-Incident ist eine Anlage kontrolliert wieder hochzufahren.

Aufgabenstellung Studierende entwickeln einen groben Wiederanlaufplan:

- Reihenfolge der Systeme
- beteiligte Rollen
- Sicherheitsprüfungen
- Entscheidungskriterien für Cold / Warm / Hot Start

Lernziel

- Verständnis für OT-Wiederanlauf
- Priorisierung von Safety und Stabilität
- Verbindung von Technik und Organisation
- Vorbereitung auf reale Krisensituationen

10.6 Transferübung: KI-Resilienz in OT

Szenario Ein Unternehmen nutzt KI zur Anomalieerkennung in einer Produktionsanlage.

Aufgabenstellung

1. Welche Resilienzgewinne bringt der KI-Einsatz?
2. Welche neuen Risiken entstehen?
3. Wie kann „Human-in-the-Loop“ umgesetzt werden?
4. Welche Safety-Grenzen dürfen nicht überschritten werden?

Lernziel

- Verknüpfung von KI-Resilienz und OT-Resilienz

- Kritische Bewertung moderner Technologien
- Systemisches Denken über IT, OT und KI hinweg

Zwischenfazit zu Kapitel 10 Die Übungen und Fallstudien:

- verbinden Theorie mit Praxis
- fördern Resilienzdenken statt Checklistenmentalität
- bereiten auf reale Entscheidungssituationen vor
- sind direkt klausur- und prüfungsrelevant

Kapitel 11 – Prüfungsrelevante Leitfragen zur OT-Resilienz

Dieses Kapitel dient der gezielten **Klausurvorbereitung** und der **inhaltlichen Selbstüberprüfung**. Die Leitfragen sind so formuliert, dass sie typische Prüfungsformate (offene Fragen, Transferfragen, Fallanalysen) abdecken und Studierende dazu anleiten, Zusammenhänge zwischen Technik, Organisation und Resilienz herzustellen.

11.1 Grundverständnis OT & Resilienz

1. **Was versteht man unter Operational Technology (OT), und wodurch unterscheidet sie sich grundlegend von klassischer IT?**

   Hinweis: Physische Prozesse, Echtzeit, Safety, Lebenszyklen.

2. **Warum reicht klassische IT-Security nicht aus, um OT-Systeme resilient abzusichern?**

   Hinweis: Patchbarkeit, Verfügbarkeit, Safety-Risiken.

3. **Welche Rolle spielt Resilienz im Unterschied zu reiner Prävention im OT-Kontext?**

   Hinweis: Akzeptanz von Störungen, Wiederanlauf, Schadensbegrenzung.

11.2 Safety, Security & Resilience

4. **Erläutern Sie den Dreiklang Safety – Security – Resilience im OT-Umfeld.** *Hinweis: Zielkonflikte und Prioritäten.*
5. **Warum hat Safety in OT-Systemen eine höhere Priorität als Security?** *Hinweis: Physische Auswirkungen, Menschenleben.*
6. **Nennen Sie ein Beispiel, bei dem eine Security-Maßnahme die Safety gefährden könnte.**

   Hinweis: ungeplante Patches, Neustarts, Segmentierungsfehler.

11.3 Architekturen & Komponenten

7. **Beschreiben Sie das Purdue-Modell (ISA-95) und erklären Sie seine Bedeutung für OT-Resilienz.**

   Hinweis: Ebenen, Segmentierung, Angriffspfade.

8. **Warum sind PLCs und HMIs besonders kritische Komponenten in OT-Systemen?**

   Hinweis: Steuerlogik, Bedienung, Manipulationsrisiken.

9. **Welche Herausforderungen ergeben sich aus Legacy-Systemen für die OT-Resilienz?**

   Hinweis: Lebensdauer, Updates, Vendor Lock-in.

11.4 Bedrohungen & Angriffsvektoren

10. **Warum wirken sich Ransomware-Angriffe auf IT-Systeme häufig auch auf OT-Systeme aus, selbst wenn diese nicht direkt kompromittiert wurden?**

11. **Erläutern Sie das Prinzip von Supply-Chain-Angriffen im OT-Umfeld.** *Hinweis: Firmware, Wartungssoftware, Dienstleister.*
12. **Warum sind Remote-Wartungszugänge ein besonders kritischer Angriffsvektor in OT-Umgebungen?**
13. **Was macht Angriffe auf Steuerlogik und Safety-Systeme besonders gefährlich?**

11.5 Organisation & Rollen

14. **Warum ist OT-Resilienz primär auch ein Organisationsproblem und nicht nur ein technisches?**
15. **Welche Rollen sind im OT-Incident-Fall zwingend einzubinden, und warum?** *Hinweis: IT, OT, Engineering, Safety, Produktion.*
16. **Beschreiben Sie typische kulturelle Unterschiede zwischen IT- und OT-Organisationen und deren Auswirkungen auf Resilienzmaßnahmen.**

11.6 Resilienzmaßnahmen

17. **Welche organisatorischen Maßnahmen sind entscheidend für OT-Resilienz?** *Hinweis: Governance, Change-Management, Dokumentation.*
18. **Warum ist Netzwerksegmentierung (Zonen & Conduits) eine zentrale Maßnahme der OT-Resilienz?**
19. **Welche Besonderheiten gelten für Patch- und Update-Management in OT-Systemen?**
20. **Warum sind Backups in OT-Umgebungen komplexer als in IT-Systemen?**

11.7 Notfallmanagement & Wiederanlauf

21. **Warum ist ein ungeplanter Shutdown in OT-Umgebungen oft gefährlicher als der Weiterbetrieb?**
22. **Erläutern Sie die Unterschiede zwischen Cold Start, Warm Start und Hot Start.**
23. **Warum ist der Wiederanlauf in OT-Systemen kritischer als die reine technische Wiederherstellung?**
24. **Welche Rolle spielen Übungen und Notfalltests für die OT-Resilienz?**

11.8 Normen & Standards

25. **Warum ist die IEC 62443 der zentrale Standard für OT-Security und -Resilienz?**
26. **Wie unterscheiden sich ISO 27001 und IEC 62443 in ihrer Zielsetzung?**
27. **Welche Rolle spielen NIST, ENISA und BSI für OT-Resilienz in Europa bzw. Deutschland?**

11.9 KI & OT-Resilienz

28. **Welche Chancen bietet der Einsatz von KI für die OT-Resilienz?**
29. **Welche neuen Risiken entstehen durch KI-basierte Systeme in OT-Umgebungen?**
30. **Warum ist das Prinzip „Human-in-the-Loop“ im OT-Kontext besonders wichtig?**
31. **Warum darf KI keine Safety-Systeme ersetzen?**

11.10 Transfer- & Reflexionsfragen (höheres Niveau)

32. **Beschreiben Sie anhand eines Beispiels, wie ein IT-Security-Vorfall zu einem OT-Ausfall führen kann.**
33. **Welche Resilienzmaßnahmen würden Sie priorisieren, wenn Patches technisch nicht möglich sind?**

34. **Wie würden Sie OT-Resilienz einem Management erklären, das primär auf Produktionskennzahlen fokussiert ist?**
35. **Warum ist OT-Resilienz ein strategisches Thema für kritische Infrastrukturen?**

Didaktischer Hinweis *Für die Klausur gilt:*

Nicht das reine Aufzählen von Maßnahmen ist entscheidend, sondern die ***Begründung****,* ***Einordnung*** *und* ***Abwägung von Zielkonflikten*** *zwischen Safety, Security, Verfügbarkeit und Wirtschaftlichkeit.*

Kapitel 12 – Glossar OT & KI

Dieses Glossar fasst die wichtigsten Begriffe aus den Kapiteln 1–11 zusammen. Es dient der **Nacharbeit**, der **Klausurvorbereitung** und als **Begriffsreferenz** für das gesamte Modul „OT-Resilienz“.

Aktor Ein physisches Element, das auf Steuerbefehle reagiert, z. B. Ventile, Motoren oder Schalter. Aktoren setzen digitale Steuerlogik in reale Bewegungen oder Zustände um.

Anomalieerkennung Verfahren (häufig KI-basiert), um Abweichungen vom normalen Betriebsverhalten zu identifizieren. In OT dient sie der frühzeitigen Erkennung von Störungen oder Angriffen.

Asset-Inventar Vollständige Übersicht aller OT-Komponenten (PLCs, HMIs, Sensoren, Netzwerke, Firmware-Versionen). Grundlage für Risikoanalyse und Resilienzmaßnahmen.

Availability (Verfügbarkeit) Eigenschaft eines Systems, bei Bedarf funktionsfähig zu sein. In OT meist höher priorisiert als Vertraulichkeit.

Backup Gesicherte Kopie von Konfigurationen, Programmen oder Daten. In OT umfasst dies u. a. PLC-Programme, SCADA-Konfigurationen und Safety-Logiken.

BSI (Bundesamt für Sicherheit in der Informationstechnik) Deutsche Behörde für IT- und OT-Sicherheit, insbesondere relevant für KRITIS-Betreiber.

CIA-Triade Klassisches IT-Sicherheitsmodell: Confidentiality, Integrity, Availability. In OT gilt oft eine andere Priorisierung.

Cold Start Vollständiger Neustart einer OT-Anlage oder Steuerung ohne Übernahme bestehender Prozesszustände. Höchstes Risiko beim Wiederanlauf.

Conduit Definierter, kontrollierter Kommunikationspfad zwischen zwei OT-Zonen gemäß IEC 62443.

Defense-in-Depth Sicherheitsprinzip, bei dem mehrere Schutzschichten kombiniert werden, um Ausfälle oder Angriffe abzufangen.

DNP3 / Modbus / Profibus Historische industrielle Kommunikationsprotokolle, häufig ohne integrierte Sicherheitsmechanismen.

ENISA EU-Agentur für Cybersicherheit, veröffentlicht Best Practices und Bedrohungsanalysen für OT und kritische Infrastrukturen.

Engineering-Workstation Arbeitsplatz zur Konfiguration und Programmierung von PLCs und SCADA-Systemen. Kritischer Angriffspunkt in OT-Umgebungen.

Failover Automatischer oder manueller Wechsel auf ein redundantes System bei Ausfall einer Komponente.

Firmware In Geräten eingebettete Software, z. B. in PLCs oder Netzkomponenten. Manipulation stellt ein erhebliches OT-Risiko dar.

HAZOP (Hazard and Operability Study) Methode zur systematischen Analyse von Gefahren in technischen Prozessen, insbesondere im Safety-Kontext.

HMI (Human Machine Interface) Benutzeroberfläche zur Überwachung und Steuerung von OT-Anlagen.

Hot Start Nahtloser Übergang auf ein redundantes System ohne Unterbrechung des Prozesses. Höchste Resilienzstufe.

Human-in-the-Loop Prinzip, bei dem der Mensch kritische Entscheidungen überwacht oder freigibt, insbesondere bei KI-Systemen.

ICS (Industrial Control System) Überbegriff für industrielle Steuerungssysteme, inkl. SCADA, PLCs und DCS.

IEC 62443 Internationaler Standard für industrielle IT- und OT-Sicherheit, zentral für OT-Resilienz.

Incident Response Strukturiertes Vorgehen zur Erkennung, Eindämmung und Behandlung von Sicherheitsvorfällen.

Integrity (Integrität) Eigenschaft von Daten oder Steuerlogik, unverändert und korrekt zu bleiben.

IT/OT-Konvergenz Zusammenwachsen von IT- und OT-Systemen, z. B. durch Cloud, IIoT oder gemeinsame Netzwerke.

KI (Künstliche Intelligenz) Algorithmen und Modelle zur Mustererkennung, Prognose oder Entscheidungsunterstützung, zunehmend in OT eingesetzt.

KRITIS Kritische Infrastrukturen, deren Ausfall erhebliche gesellschaftliche Folgen hätte (z. B. Energie, Wasser, Gesundheit).

Legacy-System Altes, oft nicht mehr updatefähiges OT-System mit langen Lebenszyklen.

MES (Manufacturing Execution System) System zur Steuerung und Überwachung von Produktionsprozessen zwischen OT und ERP.

NIST US-amerikanische Standardisierungsbehörde, relevant durch das NIST CSF und NIST SP 800-82 für OT.

OT (Operational Technology) Technologie zur Steuerung physischer Prozesse, z. B. in Industrieanlagen oder Infrastrukturen.

PLC (Programmable Logic Controller) Industrieller Steuerungsrechner zur Echtzeitsteuerung von Maschinen und Prozessen.

Predictive Maintenance KI-gestützte Wartungsstrategie zur Vorhersage von Ausfällen anhand von Sensordaten.

Purdue-Modell (ISA-95) Referenzmodell zur Strukturierung von IT- und OT-Systemen in Ebenen.

Ransomware Schadsoftware, die Systeme verschlüsselt oder blockiert. In OT oft indirekt wirksam über IT-Ausfälle.

Resilience (Resilienz) Fähigkeit eines Systems, Störungen zu überstehen, sich anzupassen und schnell wieder funktionsfähig zu werden.

Safety Schutz von Menschen, Umwelt und Anlagen vor unbeabsichtigten Fehlfunktionen.

SCADA (Supervisory Control and Data Acquisition) Zentrales System zur Überwachung und Steuerung industrieller Prozesse.

Security Schutz vor absichtlichen, böswilligen Angriffen.

Sensor Komponente zur Erfassung physischer Zustände (z. B. Temperatur, Druck, Durchfluss).

SIL (Safety Integrity Level) Maß für die Zuverlässigkeit von Safety-Systemen.

SOC (Security Operations Center) Zentrale Einheit zur Überwachung und Analyse von Sicherheitsereignissen.

Supply-Chain-Angriff Angriff über manipulierte Software, Hardware oder Dienstleister.

Warm Start Teilweiser Wiederanlauf unter Erhalt bestimmter Prozesszustände.

Zone Abgegrenzter Bereich mit ähnlichen Sicherheitsanforderungen gemäß IEC 62443.

Abschlusshinweis *Dieses Glossar bildet die terminologische Grundlage für alle OT-Resilienz-Kapitel. Für die Klausur ist es entscheidend, Begriffe* ***nicht nur definieren****, sondern* ***in Zusammenhänge einordnen*** *zu können.*

Bibliografie

[1] National Institute of Standards and Technology, „The NIST Cybersecurity Framework (CSF) 2.0“, NIST Cybersecurity White Paper CSWP 29, Feb. 2024. doi: 10.6028/NIST.CSWP.29.

[2] K. Stouffer *u. a.*, „Guide to Operational Technology (OT) Security“, NIST Special Publication 800-82 Rev. 3, Sep. 2023. doi: 10.6028/NIST.SP.800-82r3.